

PROCUREMENT

AUDIT PROGRAM #44-00-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
August 2025	All	All	Thomas Zeitz	Updated whole program, added links, workflows
July 2024	Process and Objective	PLANNING: Self-Serve Information	Elena Jimenez	Include wave 2 of Self-Serve instructions Merging Risk Area SS & FVD
April 2024	Supplier Master File	Vendor Master File Maintenance	Elena Jimenez	Move VMF back to Accounts Payable as the responsibilities in the organizations changed
December 2023	Supplier Master File	Vendor Master File Maintenance	Elena Jimenez	Move VMF from Accounts Payable to Procurement as the responsibilities in the organizations changed
December 2023	Process and Objective	PLANNING: Self-Serve Information	Elena Jimenez	Added section "PLANNING: Self-Serve Information" as part of the IDR Simplification Project
April 2023	Purchase Orders and Work Authorizations	PO001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

PROCUREMENT AUDIT PROGRAM #44-00-00

Table of Contents

PROCESS AND OBJECTIVE	3
PLANNING: Audit Program Risk Alignment	5
PLANNING: Data Analysis	6
PLANNING: Self-Serve Information	10
PLANNING: Reference Material	12
PLANNING: Fraud Template	13
CONTROL ASSESSMENT QUESTIONS BY RISK AREA	15
Key Control Question: 1. Supplier Assessment (including PIF)	15
Primary Test: Supplier Assessment (SA001.P)	16
Primary Test: Procurement Integrity Focus Suppliers (SA002.P)	19
Key Control Question: 2. Supplier Selection and Fair Value Determination	22
Primary Test: Supplier Selection and Fair Value Determination (SF001.P)	23
Key Control Question: 3. Contract Management and Supplier Deliverables	28
Primary Test: Contract Administration (CM0001.P)	29
Secondary Test: Time and Material (CM002.S)	32
Primary Test: Assets and Suppliers (CM003.P)	33
Secondary Test: Confidential Information (CM004.S)	34
Primary Test: Business Continuity (CM005.P)	35
Primary Test: Agreement Currency (CM006.P)	36
Key Control Question: 4. Purchase Order Process	37
Primary Test: Purchase Orders and Work Authorizations (PO001.P)	39
Primary Test: Letter of Authorizations (PO002.P)	41
Primary Test: Approval of Commitments (PO003.P)	42
Key Control Question: 5. Procurement Bypass	43
Primary Test: Procurement Bypass Identification (PB001.P)	44
Primary Test: Procurement Bypass Management and Reporting (PB002.P)	45
Key Control Question: 6. Measurements and Key Controls	47
Primary Test: Procurement Internal Measurement (MA001.P)	48
Primary Test: Diversity Certification and Spend Reporting (MA002.P)	49
Primary Test: Separation of Duties and System Access (MA003.P)	51
Key Control Question: 7. Environmental Programs	52
Primary Test: Import of Third-Party Products (EP001.P)	53
Primary Test: Procurement of Waste Disposal and Product Recycling Services (EP002.P)	54
Primary Test: Environmental Requirements for Supplier Deliverables to IBM (EP003.P)	55
Primary Test: Separation of Duties and System Access (MA003.P)	56
Appendix A: Instructions for FBC OpenPages	57

PROCUREMENT AUDIT PROGRAM #44-00-00

PROCESS AND OBJECTIVE

Process Definition

The procurement process is defined as the process of selecting qualified suppliers, placing purchase orders for business requirements, executing contracts with selected suppliers, and monitoring the performance of suppliers according to the terms and conditions of formal contracts. This is applicable to Global Procurement activities to support Services and General Procurement and Production Procurement. These activities all occur within a framework of ethical practices and fairness as outlined in the Procurement Policies and Practices (PP&P), commonly known as the Blue Book, and the Business Conduct Guidelines. The Federal Blue Book applies to the purchases for the U.S. Federal government. It is basically the current Blue Book plus legal practices defined by the U.S. government.

Business Objective

The Procurement team's mission is to collaborate with speed across IBM, maximizing value for our clients, suppliers, and the IBM enterprise. The vision is to deliver simple engagements focused on speed, leveraging Digitization, cognitive insights, and innovation from suppliers to maximize value. Procurement Policies and Practices must be followed by all members of Global Procurement and those organizations which have received a specific delegation of Procurement Authority from the Procurement Policy Executive.

Audit Approach: From a testing perspective, the auditable units include the Procurement E2E process: **Supplier Assessments, Supplier Selection, Fair Value Determination, Contract Management and Supplier Performance, Work Authorization, Purchase Orders, and Bypasses, Measurements and Key Controls, Environmental Programs, and Separation of Duties and Risk Assessment.**

NOTE: Procurement Application and Tools audits are performed by the Application Teams.

For Completeness Purposes

Non-PO or PO-Exempt:

PO-exempt payments are allowed for approved global non-PO categories, and the selection of the correct Commodity Code is determined by the requester. After approval of PO-exempt invoices (approval level of requester line management dependent on invoice value), invoices are processed by Accounts Payable for payment to vendor. The process is owned by the business itself, but PO-exempt categories are managed and kept by procurement.

Vendor purchases below a certain low value clip-level (determined by procurement and applicable for only specific commodity families) can be purchased directly without involvement of procurement. After approval of low value invoices (approval level of requester line management dependent on invoice value), invoices are processed by Accounts Payable for payment to vendor. The process is owned by the business itself, but low-value categories and the low value clip-level are managed and kept by procurement.

IOI (Invoice-Only-Invoice):

In countries where CAAPS is used instead of SAP, the process for PO-exempt and for low value is also called 'IOI', but the same rules do apply for IOI as for PO-exempt and low value.

CAAPS = Common Alternative Accounts Payable and Purchasing System.

PROCUREMENT AUDIT PROGRAM #44-00-00

PROCESS AND OBJECTIVE (Continued)

Spending Scope

From spending perspective, following "S2P Invoice Owning Group" will define the scope of different audit programs. Please check the universe for new groups to be included in the scope.

IOI-BM	A/P only Scope
IOI-IGFTAX	A/P only Scope
IOI-PM	General Procurement Scope
LOG	Production Procurement Scope
PROD	Production Procurement Scope
PT	A/P only Scope (Passthrough payments)
RedHat	RH Procurement Scope
S&GP	General Procurement Scope

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Audit Program Risk Alignment

General and Production Procurement

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Supplier Assessment (including PIF)	High	Supplier Assessment	SA001.P, SA002.P
Supplier Selection and Fair Value Determination	High	Supplier Selection and Fair Value Determination	SF001.P, EP002.P, SF002.S
Contract Management and Supplier Deliverables	Medium	Contract Management	CM001.P, CM002.S, CM003.P, CM004.S, CM005.P, CM006.P
Work Authorization, Purchase Orders, and Bypasses	Medium	Purchase Order Process	PO001.P, PO002.P, PO003.P
		Procurement Bypass	PB001.P, PB002.P
Measurements and Key Controls	Medium	Measurements and Key Controls	MA001.P, MA002.P
Environmental Programs	Medium	Environmental Programs	EP001.P, EP003.P
Separation of Duties and Risk Assessment	Low	Measurements and Key Controls	MA003.P

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Non-competitive Source Selection techniques	- Obtain a list of all suppliers selected by using non-competitive sourcing techniques for the audit period and get a list of all transactions for those suppliers. - Obtain a list of Procurement Integrity Focus (PIF) suppliers and transactions with government owned entities (GOEs). - Select a sample to determine if the usage of non-competitive sourcing techniques was justified and all Blue Book requirements were fulfilled.	- Incorrect sourcing codes are used. - The use of the non-competitive source selection technique is not justified. - All Procurement policy requirements - for the non-competitive source selection technique - were not properly executed and documented. - Identification of the supplier as a PIF, or not as a PIF, is not accurate and required review is not performed. - The business opportunity is awarded to the supplier prior to completing all process requirements. - The purchase order / work authorization was issued to the supplier prior to completing all process requirements. - A transaction incorrectly utilized the "Pass Thru Payment" process, instead of the correct source selection technique. "Negotiations only" fair value technique is not justified.	- Excess expenditures. - Supplier relations exposure due to failing to conduct competitive source selection technique. - Use of a supplier that is not the most skilled / qualified to provide the required goods and / or services. - Excessive supplier compensation due to failure to conduct competitive source selection technique. - Opportunity for unethical behavior / collusion between the IBM brand requestor / procurement, supplier, and customer. - Potential exposure due to failure to conduct a Legal assessment of the transaction.

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Data Analysis (continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Sourcing	- Obtain a list of purchase orders / work authorizations that are placed or extended beyond one year. - Obtain a list of PIF suppliers.	Corrective actions are not taken to address excessive or inappropriate use.	- Excess expenditures. - Potentially exposing IBM to financial loss or fraud and engaging with a supplier that does not meet our ethical standards. - Opportunity for unethical behavior / collusion between the IBM brand requestor / procurement, supplier, and customer. - Potential exposure due to failure to conduct a Legal assessment of the transaction. - Failure to comply with the requirements of IBM's supplier compliance program.

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Data Analysis (continued)

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Bypass Report	- Obtain Procurement bypass reports for the commodity or country to determine if Blue Book requirements were followed. - Obtain a report from Technology Team that identifies instances where the invoice date was prior to the PO date to determine if these instances were identified as bypasses and if the bypass process was followed. - Obtain a list of electronic check requests and miscellaneous expense account exceptions from the Audit Technology team to determine if these instances were identified as bypasses and if the bypass process was followed. (SS/FV) Obtain a cumulative commit and spend report and determine if fair value analysis was performed on multiple below clip level purchase orders (i) whose cumulative values for purchases of the same product/ service from a given supplier, or (ii) which were part of the same sourcing decision for a given supplier required execution of supplier source selection. For multiple POs with a cumulative clip level over the defined sourcing clip level, determine if sourcing selection process was followed according to Procurement policy.	- Procurement bypasses are not identified or not included in the measurements. - Source selection and fair value analysis are not performed for transactions with spend above the defined clip level.	- Lack of controls in place to monitor bypass activities. - Manipulation of measurement results. - Lack of controls in the selection of suppliers. - Potentially exposing IBM to financial loss or fraud and engaging with a supplier that does not meet our ethical standards. - Failure to comply with the requirements of IBM's supplier compliance program.

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Data Analysis (continued)

To get a risk-based sample and focus more on fraud and misuse of procurement processes use the following focus areas to optimize your sampling:

- Non-competitive Source Selection Techniques
 - Customer Directed Supplier
 - Supplier Brought or Supplier Participated Opportunity ('SBO/SPO')
 - Buyer Selected - Non-Competitive
- Competitive Source Selection Technique: Buyer Selected – Competitive
 - Transactions where a competitive sourcing technique was used but the supplier with the best price or value (the uncompetitive supplier) was not awarded the business opportunity
- Transactions with PIF suppliers that support or transact business with GOEs
 - Supplier on-boarding and revalidation. Requirements for awarding business to a supplier, and issuing purchase orders / work authorizations to a supplier, such as screening, due diligence, RBA Letter Agreement, etc.
 - Sub-tiering restrictions and due diligence requirements
 - Additional requirements for transactions in Focus Countries and / or where the transaction involves engaging with a Government Entity
 - Compliance with Supplier Integrity Course requirements
- Fair Value Analysis
 - Use of previous Buyer Selected - Competitive or RFI data to establish Fair Value
 - Use of Negotiations Alone to establish Fair Value
 - Compliance with process requirements, where the supplier awarded the business opportunity has a price that is in excess of Fair Value
- Commodity/UNSPSC Codes associated with non-tangible products, i.e., technical services, software, etc.
- Use of correct source selection codes for the transaction.
- Agents/Consultants/Lobbyist/Representatives
 - Services the supplier was contracted to deliver
 - Evidence the services were delivered in compliance with the Purchase Order issued to the supplier
 - Supplier engagements where there was only one occurrence
- Transactions below the country clip-level for Source Selection and Fair Value Analysis
 - Multiple purchase orders with the same supplier (i) whose cumulative value for purchases of the same product/service from a given supplier, or (ii) which were part of the same sourcing decision for a given supplier requires execution of Supplier Selection and Fair Value.
- Transactions that require review by the Procurement Ombudsman, Compliance & Investigations (C&I) or Legal, i.e., non-competitive source selection techniques, GOE procurement bypasses, etc.

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Self-Serve Information

Some information previously included in the Initial Data Request (IDR) items which continue to be relevant information in audits will now be extracted directly by the audit team. These are as follows:

Business Objectives and Mission	Publisher page for non-Procurement IBMers: Procurement@IBM Publisher page for Procurement employees including all-Hands meeting recordings: Procurement - Global Procurement
Procurement Process Flow is included in Blue Book, Chapter 1.6 "The Procurement Process"	https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/blue-book
How to request Buy@IBM access for the audit team and education material	https://uaweb.gsib.fringe.ibm.com:9443/bondweb/customers - Enter w3 credentials - select "Buy@IBM" from the list - select "Request/Change special access" - enter user's email address - select "IBM Auditor (View only)" from "User Group" scroll down menu, provide business justification and submit Procurement Academy - Buy@IBM
Which countries are still in legacy tools and which are migrated to Ariba can be seeing in the Buy@IBM deployment plan	Buy@IBM User Resources - Global Deployment Plan
How to request relevant EPM access	- Check your access to "EPM Production" in AccessHub - If you already have "EPM Production" access use the "Modify" option, otherwise "Request New Account" - Recommended access for CA&AS is "your GEO" + "All Business Units" - Under "Additional Specialized Accesses" select "Source to Pay: Non-S2P Personnel - Analyst – Read"
How to request access to CAAPS	
How to request access to FindGOE	https://ibm.ent.box.com/s/43p9ibbkr829enrdyhmc8kyfwksg6h
List of family, and commodity codes and UNSPSC codes with their description, and those eligible for non-PO (PO exempt/IOI) process	PO: https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/commodity-categorization non-PO: https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/non-po-categories
List of source selection codes:	https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/source-selection-codes

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Self-Serve Information (continued)

Non-PO Processes: PO Exempt and Low Value Process: Please provide the invoice only invoice/PO exempt process and the low value process including the list of commodity codes eligible for non-PO (PO exempt/IOI)	https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/non-purchase-order-process
Terms and acronyms: A glossary of terms and acronyms used within the Procurement process and their description.	https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/acronyms
Executive Advocate List: Please provide a listing of all EAP accounts on the Executive Advocate Program List and the related suppliers.	https://w3.ibm.com/w3publisher/executive-advocate Current assignments: https://w3.ibm.com/w3publisher/executive-advocate/current-assignments
List of Procurement Integrity Focus (PIF) Suppliers	https://w3.ibm.com/w3publisher/globalsupplieronboarding/pif-reports-integrity-training-waivers
Diversity EPM report	Diversity (S2P on EPM) Navigate to relevant filter to drill down to specific market or country
EPM reports for the list of all payments to suppliers and the list of all purchase orders	S2P Data & Dashboards EPM Procurement Audit reports - Data Please scroll down in publisher to the section called "Procurement Audit" Alternative direct access to EPM Reports: EPM Procurement Audit Content Or following the path "Team content / Co-creation / Source to Pay / Reports / Procurement Audits"
- Management Self-Assessment of Controls (MSAC) - Risk Acceptance (RA's) - Key Control over Financial Reporting (KCFR) control points - KCFR defects	Instructions on FBC OpenPages – see Appendix A

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Reference Material

IBM Global Supply

- Global Procurement Policies & Practices Publisher Page:
<https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices>
- The Blue Book: <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/blue-book>
- Procurement Education: <https://procurement-academy.dal1a.cirrus.ibm.com/>
- Tools: <https://w3.ibm.com/w3publisher/procurement-ibm/tools-reporting>
- Global procurement: <https://w3.ibm.com/w3publisher/procurement>
- S2P tools: <https://w3.ibm.com/w3publisher/procurement/tools-processes/data>

Corporate Instructions (CI) and Guidelines

- <https://w3.ibm.com/ibm/corporate-documents/>
- FIN 101: Control of Disbursements <https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>
- PROC 167: Supplier sourced goods and services <https://w3.ibm.com/ibm/corporate-documents/proc/proc-167>
- FIN 168: Business amenities and gifts <https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>
- IPL 101: Rights to intellectual property resulting from work performed by or for IBM under contract <https://w3.ibm.com/ibm/corporate-documents/ipl/ipl-101>
- IPL 106: Receipt and disclosure of confidential information <https://w3.ibm.com/ibm/corporate-documents/ipl/ipl-106>
- ENV 205: Integrating environmental requirements into the global procurement process <https://w3.ibm.com/ibm/corporate-documents/env/env-205>
- Corporate Policies on Privacy <https://w3.ibm.com/ibm/privacy/knowledge-base/corporate-policies>
- FIN 182: <https://w3.ibm.com/ibm/corporate-documents/fin/fin-182> (includes Management Self-Assessment of Control)
- CIO 163 3rd Party IT Spend – Internal Software <https://w3.ibm.com/ibm/corporate-documents/cio/cio-163>

Organization and Policy Letters

- Organization Letter 131: Delegation of Authority - Procurement <https://w3.ibm.com/w3publisher/corporate-documents/corporate-directives/corporate-organization-letters/col-131>
- Policy Letter 107: Reciprocity <https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-policies/cp-107>

Other Contacts and Resources

- Internal Audit IT Support
- IBM Legal
- Internal Audit Procurement process focal
- Privacy and Security guidelines https://w3.ibm.com/w3publisher/w3_tools_privacy_and_security

PROCUREMENT AUDIT PROGRAM #44-00-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Kickbacks, collusion, preferential treatment	Supplier Selection (SS) and Fair Value Determination (FVD)	• Test SS and FVD E2E execution: Compliance and justifications for supplier usage, RFQ process, etc. • Check if vendor is not a preferred supplier, or local instead of suppliers with global contracts were used and determine the decision to use them anyhow. • Review POs and A/P transactions to identify purchases made without valid PO. • Review exceptions and samples of non-POs (IOI) to verify if they were properly managed, approved, and documented. • Testing should include focus on non-competitive selection techniques to ensure that Procurement met the requirements for the particular selection technique and sufficient documentation and business rationale exist. • Test supplier transactions identified as below clip levels to ensure that they actually fall below clip levels and that the supplier selection decisions for those transactions appear reasonable and properly documented.
Conflict of interest (buyer/client has financial interest in supplier)	SS and Supplier Assessment	
Improper payments to suppliers	SS, FVD, management review of disbursements, procurement bypass tracking, PO and supplier payment testing	
Procurement bypass	Management review of disbursements, procurement bypass tracking	Review POs and A/P transactions to identify purchases made without valid PO.

**PROCUREMENT
AUDIT PROGRAM #44-00-00**

PLANNING: Fraud Template (continued)

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Dummy Company	Supplier Assessment Process	Watch for: • Vendors with only a post office box address or personal e-mails, only cell phones for business numbers, lacking a professional website, very poor and incomplete financials, vendors not listed in country. Invoices that have been coded to numerous bookkeeping accounts (the perpetrator is spreading the amounts to minimize the effect). Also look at sub-tiering, sole source, and orders placed to sole agents.

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS BY RISK AREA

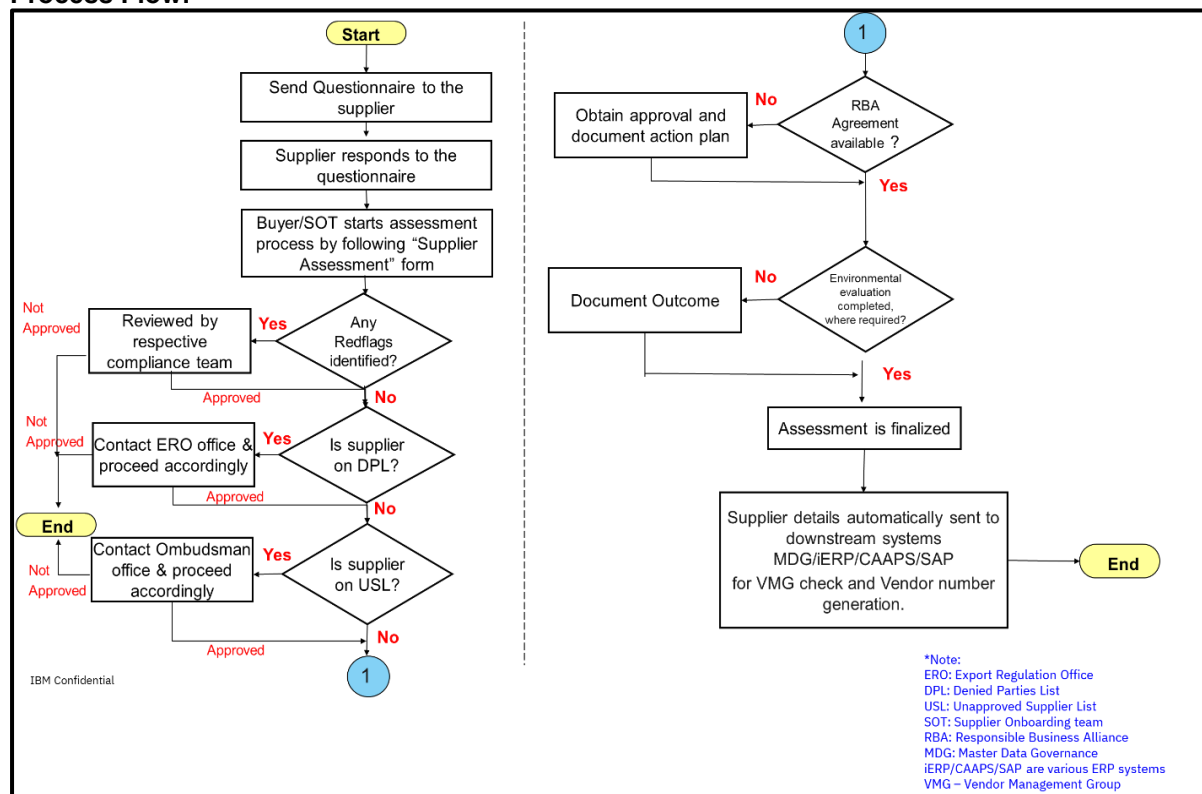
Key Control Question: 1. Supplier Assessment (including PIF)

Procurement Task:

Before IBM places a Purchase Order (PO)/ Work Authorization with “new” external suppliers, Procurement has the responsibility to ensure suppliers are evaluated and assessed to verify they meet Procurement criteria for qualified suppliers. These criteria include financial solvency, compliance with applicable international, national and local laws and regulations, IBM technology and technical standards, IBM's social and environmental requirements, IBM's Supplier Shipping Instructions for Export to IBM, IBM's ethics and anti-bribery requirements and the ability to meet IBM's demand.

Reference: Blue Book – Section Supplier Management/New Supplier Assessment

Process Flow:



PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS BY RISK AREA

Key Control Question: Supplier Assessment (incl PIF)

Primary Test: Supplier Assessment (SA001.P)

Objective:

To validate if Procurement's supplier assessment policy is designed and being effectively and accurately executed and controlled to address business risks, to protect IBM's interests, and to ensure that the best value was received for IBM.

Risk/Exposure:

Failure to correctly assess new suppliers and (re-)validate procurement integrity focus (PIF) suppliers could lead to inappropriate transactions, financial loss, and disputes. Also, it could impact the business by selecting inadequate suppliers. FCPA risk.

Approach:

Select risk-based samples to validate that new suppliers were on-boarded based on actual business needs, and the mandatory validation for new suppliers was performed timely and supported with required document.

Assessment Questions

1. Was the supplier, its owner, and the individuals listed on the Supplier Questionnaire checked against the Denied Parties List (DPL), Unapproved Supplier List (USL), and the Executive Advocate Program List prior to awarding business to the supplier?
 - a. Was the screening process conducted in accordance with the provisions of USERP Section 4, Part 1.2.1?
 - b. Was the supplier screening documented with the date conducting the screening?
 - c. If the supplier, its owner, and any of the individuals listed on the Supplier Questionnaire was on the DPL or the USL, was approval to use the supplier obtained prior to awarding the business opportunity?
 - d. If the supplier was on the Executive Advocate Program List, was the IBM Client Executive for all cases and the IBM Partnership Executive for significant activity notified of the decision to use the supplier?
 - e. Does sample testing confirm that new suppliers are screened against the DPL before they are added to an IBM Vendor Master File (VMF)?
2. For all on-boarded IBM suppliers, were all process requirements successfully completed as per the Supplier Assessment Form prior to the issuance of a Purchase Order or Work Authorization?
 - a. For Procurement Integrity Focus (PIF) suppliers, was the supplier questionnaire completed and reviewed? Verify if all required additional assessments were conducted as per Blue Book Section "New supplier Assessment."
 - b. For non-PIF suppliers, was the Supplier Questionnaire completed along with all of the requirements of the Blue Book Section "New supplier Assessment."
3. Was the supplier enabled to process electronic purchase orders, invoices, payments and disbursements in all geographies where it was not prohibited by local law or an exception by the appropriate Second Line Leader was properly approved?
4. Where applicable (e.g., for suppliers providing hazardous waste, special waste and end-of-life product management services or having other processes with potential environmental impacts), was an environmental evaluation of the supplier performed as required in Corporate Instruction ENV205: Environmental Evaluation of Suppliers "Integrating Environmental Requirements into the Global Procurement Process". If not, how was the decision not to perform this evaluation determined? Was an evaluation of the supplier's quality management system performed?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS BY RISK AREA

Key Control Question: Supplier Assessment (incl PIF)

Primary Test: Supplier Assessment (SA001.P)

(Continued)

5. Was the Responsible Business Alliance (RBA) Letter Agreement signed for all suppliers in accordance with publicly stated policy on IBM's external website and as outlined in the Blue Book Section "Responsible business Alliance Letter Agreement"?

NOTE: Any exception needs approval by a Procurement VP and the Project Executive for Supply Chain Social Responsibility.

In addition to these exceptional approvals, the supplier must sign the "Ethics and Integrity Letter Agreement" or, for PIF suppliers, Legal/ Compliance & Investigations (C&I) approval is required to proceed without such agreement, and, for non-PIF suppliers, the Chief Procurement Officer approval is required to proceed without such agreement.

6. Was the IBM Security Letter Agreement (SECLA) signed for suppliers considered "Strategic" and providing/arranging for tangible goods shipments as outlined in the Blue Book Section "Supply Chain Security – SECLA Requirement"?
7. Was it verified that the supplier has a management system that effectively manages corporate responsibility and environmental matters as outlined in the Blue Book? Also, did the Sourcing organizations define a global monitoring plan that provided adequate coverage for their suppliers in assuring supplier compliance to IBM's Social and Environmental Management System (S&EMS) requirements as outlined?
8. Did Procurement provide suppliers with Instructions for Cross-Border Shipments to IBM Corporation (SPIs) for every country to which supplier shipped to?
9. Were current financial reports used to evaluate suppliers (e.g., Dun & Bradstreet)? Had Procurement determined what levels of financial risk were acceptable? If a company was over the level of acceptable risk, was an assessment of the risk determined, and Procurement management approval obtained?
10. Safety and environmental requirements (NOTE: these are mainly applicable in production procurement commodities).
 - a. Were all purchases of chemicals and other hazardous materials done after receiving approvals of the site Chemical Coordinator?
 - b. When IBM requests a supplier to use hazardous material or equipment involving hazardous material, was an environmental evaluation performed, and any issues properly remediated?
 - c. Do the contracts with hazardous waste disposal vendors comply with procurement guidelines?
 - d. Did all purchases meet the applicable IBM and regulatory health and safety requirements? Look for purchases of commercial electrical products; non-product equipment for IBM internal use; equipment involving hazardous materials, radioactive sources or lasers; contracts for on-site contractor file services.
 - e. Were all suppliers in compliance with the IBM policy regarding Ozone-Depleting Chemicals (ODC)? IBM will no longer accept any product or part from a supplier that contains or was manufactured using Class 1 ozone depleting chemicals known as chlorofluorocarbons, halos, methyl chloroform, and carbon tetrachloride. If a supplier is not in compliance or is unable to comply with this ODC policy, then they are held responsible to contact IBM to have their situation reviewed. All exceptions must be pre-approved by the Chief Procurement Officer, documented and maintained on file for periodic review. In addition, CHQ Tax and CHQ Distribution must be copied on all exceptions granted by procurement.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS BY RISK AREA

Key Control Question: Supplier Assessment (incl PIF)

Primary Test: Supplier Assessment (SA001.P)

(Continued)

- f. Were potential contractors evaluated against safety performance objectives? Look for submissions of company OSHA rates, insurance experience modification rates, written safety programs, and past safety performance on IBM premises (outside the US equivalent country data should be used).
 - g. Where applicable, was the proliferation screening completed before Procurement conducted business with a supplier? NOTE: This only applies to Procurement units who conduct business with suppliers located in countries that the US Government has identified as raising proliferation concern and to whom IBM will provide hardware, software, or technology as part of the engagement (refer to USERP Section 4, Part 2.5). Was the full list of requirements, as provided in Trade compliance guidance, followed and were additional regulatory requirements and regional legal requirements assessed?
11. Identify if any fraudulent activity occurred, particularly where we have purchased consulting services or if suppliers were selected via the Buyer Selected - Non-Competitive or Customer Directed Supplier sourcing techniques.
12. If there were any potentially adverse findings identified during the due diligence / vetting process, were these findings remediated prior to awarding the opportunity to the supplier?
13. If the new supplier was an Intermediary, was the addition approved by the appropriate category/council chair.

Data Universe:

The universe of new/active suppliers can be pulled out of EPM:

- 1. New suppliers:
[EPM Reports for Procurement Audit](#) In the section Procurement Audit look for Supplier reports report. Click on Folder symbol in the lower right corner – Select New Vendor report.
Filters to apply: Geo/Market/Country, Audit time frame, new or extension
- 2. Active suppliers:
[S2P Data & Dashboards](#) In the section Procurement audit look for Active Vendor report.
Filters to apply: Geo/Market/Country, Audit time frame, PO and Invoice issuing dates to be identical with audit period.

Available reports from Analysis Team:

New Suppliers where a PO will be created within a few days after supplier creation date for a larger amount

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Supplier Assessment (incl PIF)

Primary Test: Procurement Integrity Focus Suppliers (SA002.P)

IBM must be able to identify Government Owned Entities (GOE) to ensure compliance with the Foreign Corrupt Practices Act (FCPA) and other anti-bribery and corruption related laws around the world.

Procurement Task:

Prior to the Award of Business:

1. The supplier must complete and submit the Supplier PIF Questionnaire.
2. Procurement must review the completed Supplier PIF Questionnaire and conduct diligence on the supplier, its key personnel and owners in accordance with the requirements of the governing process.

Sub-Tiering:

Prior to allowing any PIF supplier to use a sub-tier supplier, Procurement must:

1. Check with the client/requester to ensure there are no flow-down restrictions in Customer Agreements inclusive of any Customer terms and conditions that prohibit sub tiering of suppliers. Document the results of this analysis.
2. Ensure that IBM's restriction and requirements on sub tiering are satisfied. These restrictions and requirements are set forth [here](#).

Integrity Training:

A PIF supplier must be in compliance with IBM's "Integrity in Supplier Relationships" on-line course requirements. IBM requires this training in connection with the onboarding and revalidation of PIF suppliers.

Supplier Revalidation:

IBM revalidates PIF suppliers to keep an ongoing focus on the importance of ethics and integrity. As part of the PIF Supplier revalidation process, at a minimum of once every three years for each PIF supplier:

1. The supplier must complete and submit the Supplier PIF Questionnaire.
2. Procurement must review the completed Supplier PIF Questionnaire and conduct diligence on the supplier, its key personnel and owners in accordance with the requirements of the governing process.

Reference: Blue book – Section Procurement Integrity Focus ("PIF") Suppliers

PROCUREMENT AUDIT PROGRAM #44-00-00

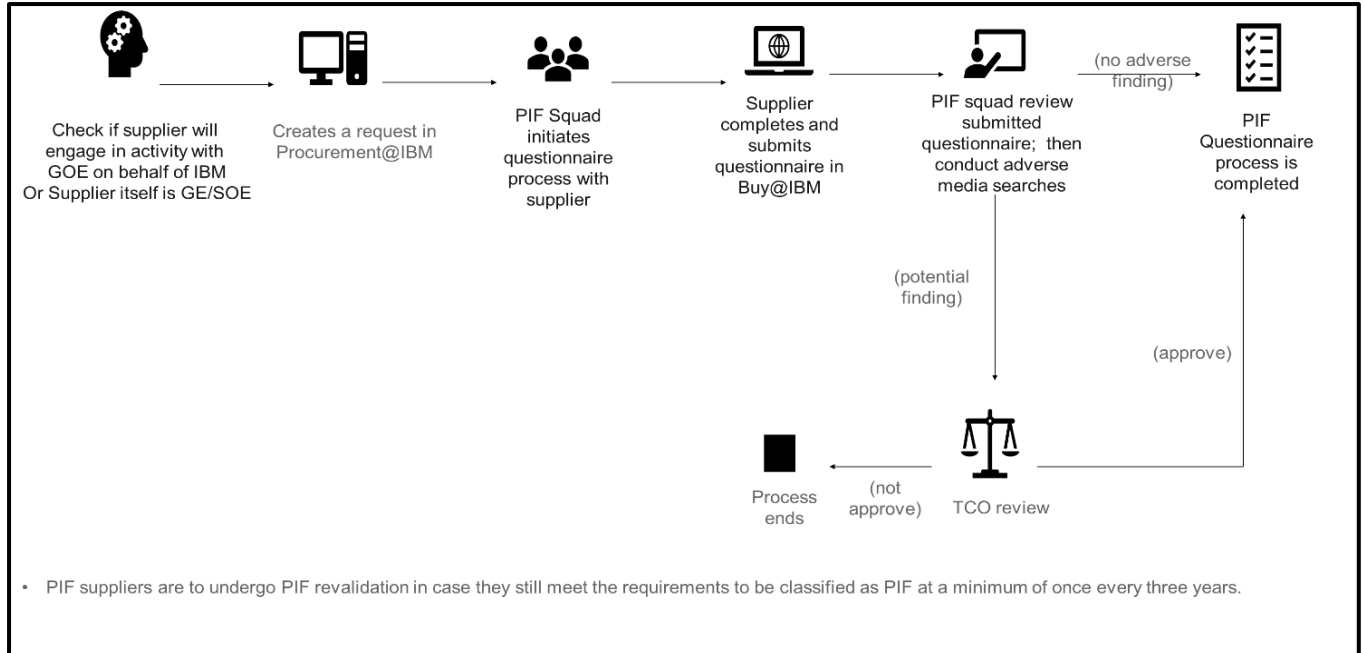
CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Supplier Assessment (incl PIF)

Primary Test: Procurement Integrity Focus Suppliers (SA002.P)

(Continued)

Process Flow:



Objective:

To validate if Procurement's supplier assessment policy is designed and being effectively and accurately executed and controlled to address business risks, to protect IBM's interests, and to ensure that the best value was received for IBM. Specifically, to verify if Procurement Integrity Focus (PIF) suppliers were appropriately identified, reviewed, and re-assessed.

Risk/Exposure:

Controls over the supplier assessments may be incomplete or inaccurate, which could lead to inappropriate transactions, financial loss, and disputes

Approach:

Review the relevant section of the Blue Book for the definition of PIF suppliers.

Select risk-based samples to validate that the mandatory validation for PIF suppliers was performed timely and supported with required documentation, PIF suppliers were appropriately identified, and requirements were completed prior to the award of the business.

Additional diligence is required when having identified PIF suppliers. NOTE: Designation of a PIF supplier is required regardless of whether the spend with that supplier is over or under the SS/FV clip level.

Assessment Questions

Review the Blue Book for the definition of PIF suppliers. Additional diligence is required when having identified PIF suppliers. NOTE: Designation of a PIF supplier is required regardless of whether the spend with that supplier is over or under the SS/FV clip level.

1. Verify if the supplier was properly classified as a PIF or non-PIF supplier (using the assessment criteria as outlined in the section of the Blue Book).

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 1. Supplier Assessment (incl PIF)

Primary Test: Procurement Integrity Focus Suppliers (SA002.P)

(Continued)

2. Verify if all the requirements set forth in the Blue Book were completed prior to the award of business.
 - a. Completion/review of supplier PIF questionnaire and conducting diligence/vetting on the supplier (including key personnel, owners) prior to the award of business.
 - b. Compliance to sub-tiering restrictions incl. review of flow-down restrictions from customer agreements.
 - c. The integrity training by the PIF supplier was completed in a timely manner and it was monitored by Procurement. The integrity training has to be performed during the PIF identification/revalidation process. The training must be completed once every three years, as part of the revalidation process.
3. Verify if PIF suppliers were revalidated once every three years and revalidation is properly documented. Note: This revalidation is required only if the supplier continues as a PIF supplier beyond the three-year-period. Suppliers that no longer fit the definition of a PIF supplier do not require revalidation.
4. For an intermediary where the transaction involves an end supplier that is engaging in or will engage in any of the actions described in Section PIF Suppliers, ensure both the intermediary and the end supplier are following all of the requirements set forth in the Blue Book.
5. For Distributors, where the Distributor is engaging in or will engage in any of the actions described in Section "PIF Suppliers", ensure the Distributor is following all the requirements set forth in the Blue Book.

Data universe:

The universe of PIF suppliers can be pulled out of EPM

<https://w3.ibm.com/w3publisher/globalsupplieronboarding/pif-reports-integrity-training-waivers>

Available reports from Analysis Team:

1. GOE Transactions: POs created, and invoices paid during the audit period that have been identified as GOE
2. Potential PIF Suppliers: This report compares the PO + Invoice Analytics data vs. PIF Report to identify potential PIF suppliers.
3. Intermediate suppliers

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Supplier Selection and Fair Value Determination

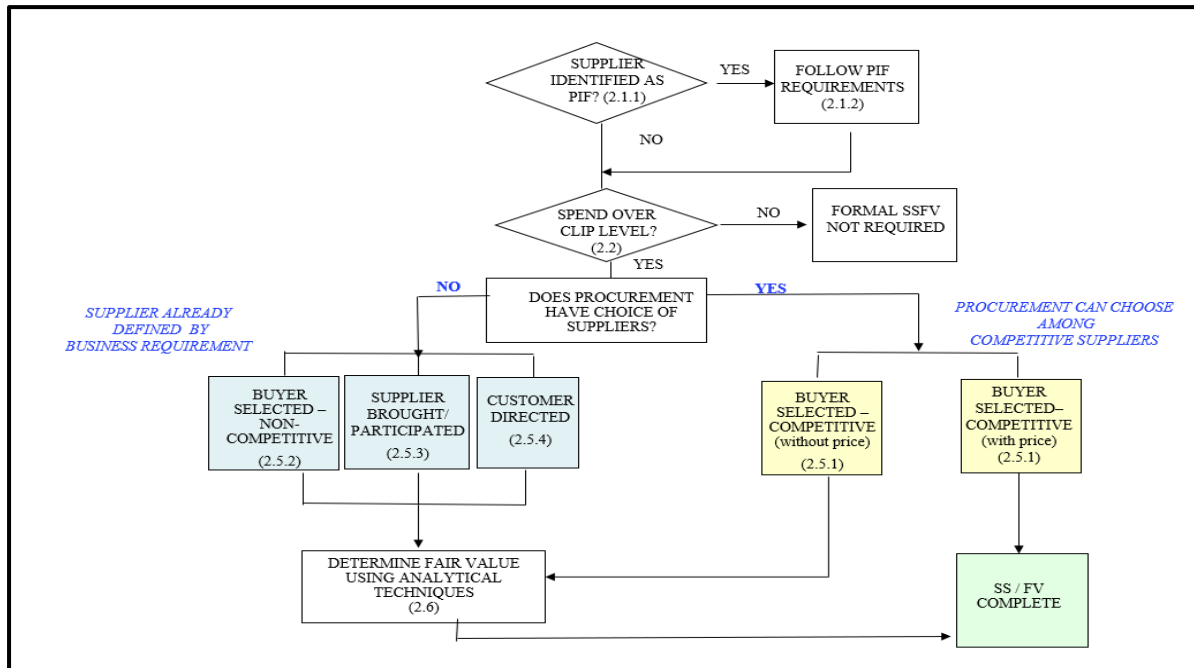
Procurement Task

Procurement is required to use an appropriate supplier selection technique when the projected value of the transaction(s) or sourcing decision is over the applicable Supplier Selection/Fair Value Clip Level.

Reference

Blue Book – Sections Supplier Selection Techniques and Fair Value Techniques

Process Flow



PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Supplier Selection and Fair Value Determination

Primary Test: Supplier Selection and Fair Value Determination (SF001.P)

Objective:

To validate that controls over the supplier selection and fair value determination process were adequately designed and executed to protect IBM's interests for a specific purchase opportunity.

Risk/Exposure:

Failure to properly perform supplier selection and fair value determination could result in excess expenditures, lower quality of goods or services, impair IBM's ability to meet commitments, and could negatively impact IBM's image. FCPA risk.

Approach:

Identify High-Risk Transactions: Utilize Commodity/UNSPSC Code or country spend reports and the Data Analysis document to identify potentially high-risk transactions, segments, and commodities. Additionally, identify situations where IBM business partners or clients are also suppliers, and where suppliers are or should be classified as Procurement Integrity Focus (PIF) suppliers.

New Suppliers and Low-Value Transactions: Identify new suppliers, services/products purchased from them, and suppliers with low-value transactions (under the country clip level) or a low number of transactions.

Sample Selection: Select a sample of purchasing transactions from higher-risk areas, including:

- Purchase orders with a rolling 12-month spend exceeding established procurement clip levels.
- A small number of samples representing suppliers with a single purchase order or low volume of spending.

Testing: Test the selected samples against the following criteria to ensure compliance with Procurement policy:

- Source Selection technique and Fair Value determination.
- Appropriate supplier selection technique used.
- Fair value analysis completeness, accuracy, and timeliness.
- Required approvals obtained before commitment.

Risk-Based Sampling: Select risk-based samples of purchases above the SSFV country clip level to determine:

- Correct application of the supplier selection technique.
- Completeness and accuracy of fair value analysis.
- Correct recording of mandatory details in the system.

Diverse Business Relationships: Verify that sourcing decisions over the SSFV clip level using a buyer-selected competitive technique met diverse business relationship requirements, including inviting diverse suppliers.

Purchases on Hold: Determine if any purchases were executed while projects were on hold.

Clip levels: Check if transactions were exceeding clip levels and related actions were executed.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Supplier Selection and Fair Value Determination

Primary Test: Supplier Selection and Fair Value Determination (SF001.P)

(Continued)

Assessment Questions

General:

1. Was the correct supplier selection technique code used?
2. For PIF: Determine if the supplier classification as PIF or non-PIF was appropriate and if all required additional assessments were conducted prior to the award of business. See section SA002.P.
3. For competitive RFPs/RFQs: Was at least one diversity supplier included in any competitive selection technique? Exceptions as per Blue Book 2.4 or approval from the Supplier Diversity Program Director.
4. Was proliferation screening performed prior to transacting business with the supplier?
5. Was there a documented process in place to monitor supplier spend to consider when to renegotiate the prices, terms, or conditions? For example, was there a process to monitor whether the clip level for source selection was exceeded?

'Buyer Selected - Competitive' Selection Techniques:

1. If less than the minimum number of required suppliers submitted a bid and it was not possible for Procurement to send out a new proposal, and the customer is in a Focus Country, was a Legal/ Compliance & Investigations (C&I) transaction review completed?
2. If the opportunity was awarded to a supplier other than the one with the best price/value? Buyer must document the rationale. If the customer is in a Focus Country, was a Legal/Compliance and Investigations (C&I) transaction review completed?
3. If only two acceptable responses are received, did the buyer confirm and document that the suppliers were unrelated financially?
4. Were all incumbent suppliers included? If not, was the reason for excluding the incumbent supplier documented?
5. Were the requirements communicated to all suppliers at the same time?
6. Were any updates to the requestor's requirements or extensions of the bid submission due date communicated to all participating suppliers at the same time?
7. Was Procurement management approval obtained for late supplier responses that were selected as the winning bid?
8. Were suppliers advised of their selection or non-selection on a timely basis?
9. Was a summary of the source selection analysis and decision documented?
10. Verify that requesters/clients/opportunity owners are not copied on RFP/RFQ requests to suppliers.
11. If the difference between the lowest and next lowest price on a final bid is more than 25%, was a comparison of the pricing to available industry/market pricing from non-bidding suppliers performed by an FLL or another buyer with subsequent FLL review?
12. Did the buyer have enough Delegation of Procurement Authority (DPA) to cover the value of the sourcing decision?
13. If awarded to a supplier other than the one with the best overall price/score, was the rationale documented and were appropriate approvals obtained, as applicable?
14. If using a Reverse Auction, were suppliers notified they are participating in a Reverse Auction?
15. If using a Reverse Auction to determine the price element of a multi-factor Competitive Evaluation, were suppliers notified that the best price is not the sole factor to determine the "winner"?
16. For multi-factor Competitive evaluations, were requirements followed as per the Blue Book?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Supplier Selection and Fair Value Determination

Primary Test: Supplier Selection and Fair Value Determination (SF001.P)

(Continued)

'Buyer Selected - Non-Competitive' Selection Techniques:

1. Was there documentation provided by Procurement that justified the selection of the supplier without the use of a competitive sourcing technique?
2. In case of a "Sole Distributors", did Procurement obtain confirmation from the OEM provider to confirm the Sole Distributor status?
3. Was the approval of an FLL with sufficient DPA obtained prior to the award of business?
4. Was there evidence that a Fair Value determination was completed?

Supplier Brought or Supplier Participated Opportunity (SBO/SPO):

1. Did the supplier meet the requirements for the opportunity?
2. Was there evidence that a Fair Value determination was completed?
3. For a Supplier Participated Opportunity, was the justification for the sourcing decision documented, and the approval of a Geography Procurement Executive obtained?
4. For a Supplier Brought Opportunity, was (i) confirmation in writing obtained from the supplier on its role in generating the opportunity, and (ii) approvals of the Country or Business Unit Chief Financial Officer, Country Business Unit Executive, and Geography Procurement Executive obtained?

Customer Directed Supplier:

1. NOTE: If "Customer Directed Supplier", the requirements of this Blue Book section apply regardless if the supplier could also be classified as any other sourcing technique.
2. Is there evidence of a written communication from a permissible form as defined in the Blue Book directing IBM to use a specific supplier, for specific services, for a specific period of time?
3. Was a review by Legal/ Compliance & Investigations (C&I) conducted in the event IBM wished to proceed with a tender/bid based on a government entity's subsequent retraction of its direction or inability to provide acceptable written documentation?
4. If PIF supplier, was a Legal approval obtained to confirm the appropriateness of proceeding with the transaction?
5. Was there evidence that a Fair Value determination was completed and approved?
6. If a more competitive (a price that is 10% or \$50,000 less than the customer directed supplier) supplier was available in support of a customer in a focus country, did the IBM requester communicate the identity of that supplier and its pricing in writing to the customer? Did the customer accept in writing the more competitive supplier or provide a rationale for a decision to keep the uncompetitive supplier?
7. If the customer located in a Focus Country rejected the more competitive supplier, was the transaction reviewed by Compliance & Investigations (C&I)?
8. Was the justification for the sourcing decision document, and approval of a First Line Leader with sufficient delegation of authority obtained prior to the award of business?

International Boycotts:

1. Had there been any boycott requests within the audit period? If yes, were requests reported immediately and did the boycott reports include all data elements as required by U.S. Export Regulation Program (USERP) Section 5, Part 2 – Antiboycott Compliance.

Fair Value Determination:

If a 'Buyer Selected – Competitive' selection method which included price was used for supplier selection, a separate fair value analysis is not required.

Where required, Fair Value (FV) can be established using either Price Comparison, Cost Buildup, or Negotiation Alone analytical techniques.

1. Was an analytical technique (either price comparison, cost buildup, or negotiation) used to establish fair value, and were the results of the Fair Value analysis documented?
2. Was the Fair Value analysis performed in accordance with applicable validity periods defined by Sourcing Councils?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Supplier Selection and Fair Value Determination

Primary Test: Supplier Selection and Fair Value Determination (SF001.P)

(Continued)

Price Comparison:

1. Was valid industry data or benchmark pricing information from a trusted and independent source for the same or similar product or service used for the price comparison? (or)
2. Was the price with an IBM supplier for a similar product or service for which the fair value had already been determined using Price Comparison or Cost Buildup used for the price comparison? (or)
3. Were results of SS/FVD that were used to determine a strategic/core supplier base for repetitive use within a country/geography with established FV rates (e.g., a rate card) used for the price comparison? (or)
4. Was a target price provided by the IBM Sales team (opportunity owner, bid manager, or similar roles) as the price to be met to win an IBM business engagement, together with other market data, used for the price comparison?
5. If there were no other sources of comparable and valid industry or IBM supplier pricing available, were the results of a previous Buyer Selected - Competitive or RFI pricing used for the price comparison? Was a justification documented as to why other sources were not able to be found, and did the Buyer determine that this price accurately reflects market prices and value.
6. Was the pricing information used in the price comparison current (not exceeding the FV validity period for the commodity) and relevant to the country/geography and time period of the price comparison?
7. Was a summary of the price comparison analysis and decision on the competitiveness of the price documented?
8. Was the approval of a Procurement Sourcing Professional with sufficient delegation of authority to cover the value of the sourcing decision obtained if the supplier was determined to be uncompetitive and the decision was made to stay with the uncompetitive supplier? If the decision was made to stay with the uncompetitive supplier and the supplier is classified as a PIF supplier and the customer is in a Focus Country, was the transaction reviewed with Compliance & Investigations (C&I) and only proceeded in accordance with their instructions?

Cost Analysis:

1. Was current and relevant industry/benchmark material costs and labor rates used to identify the most competitive cost? (or)
2. Were agreements with specified price lists where FV was established using Price Comparison or Cost Buildup and which were put in place by Sourcing Councils or other IBM locations used as part of the analysis?
3. Was the analysis performed by the buyer or a team including Procurement function? Was the result reviewed by the business unit?
4. Was the summary of the Cost Buildup analysis and decision on the competitiveness of the price documented?
5. Was the approval of a Procurement Sourcing Professional with sufficient delegation of authority to cover the value of the sourcing decision obtained if the supplier was determined to be uncompetitive and the decision was made to stay with the uncompetitive supplier? If the decision was made to stay with the uncompetitive supplier and the supplier is classified as a PIF supplier and the customer is in a Focus Country, was the transaction reviewed with Compliance & Investigations (C&I) and only proceeded in accordance with their instructions?

Negotiation Alone - The use of Negotiation Alone to establish Fair Value is allowed:

1. Always When performing revalidation of Fair Value
2. When performing Fair Value on new sourcing decisions, a buyer may use Negotiations Alone for FV where they have documented the reasons why Price Comparison, Cost Buildup and Buyer Selected – Competitive techniques could not be used.

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 2. Supplier Selection and Fair Value Determination

Primary Test: Supplier Selection and Fair Value Determination (SF001.P)

(Continued)

Where 'Negotiation Alone' was used to determine Fair Value, did one of the following situations apply:

1. Revalidation of FV (i.e., when FV was previously determined and the validity period is expiring), or
2. FV on a new sourcing decision, where a buyer has documented the reasons why Price Comparison, Cost Buildup and Competitive Bidding techniques are unable to be used. If the supplier(s) in these cases are identified as Customer Directed, Supplier Brought Opportunity, or Supplier Participated Opportunity, and the customer is a GE/SOE in a focus country, was the use of Negotiations Alone for FV reviewed by Compliance & Investigations (C&I)?

Re-Evaluation of Fair Value

1. Were exceptions to the established guidelines approved by the Procurement Sourcing VP or his/her delegate?
2. For sourcing from a PIF Supplier for an external customer: Was Fair Value re-evaluated based on the fair value validity period?

For Intermediaries:

1. Was SS and FVD conducted for any end supplier where the annual IBM spend exceeded the applicable entity clip level and for any fee paid by IBM to an integrator where the cumulative value of fees paid for managing end supplier services exceeded the applicable entity clip level?

NOTE: Intermediaries may not be used for any end supplier:

- a. That was selected via Supplier Brought Opportunity/Supplier Participated Opportunity.
- b. For Environmental purchases involving Hazardous Waste and Special Waste.
- c. Where the payment is made via a non-PO method or expense reimbursement process.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Procurement Task:

Refer <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices>

Reference:

Blue Book Section Supplier Agreements and Publisher Site – see link above

Process Steps:

See <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/contracting-process>

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Primary Test: Contract Administration (CM0001.P)

Objective:

To validate if controls over agreements were adequate to ensure proper administration of the purchase activity and a well-defined business relationship between IBM and its suppliers. Specifically, to verify if contracts include detailed scopes of work, appropriate business and legal clauses, definition of supplier performance measurements, and supporting documentation which demonstrate an effectively managed contractual supplier relationship. In addition, determine the validity of the data reported for the agreement management measurement.

Risk/Exposure:

Ineffective or insufficient controls over the contract management process could lead to supplier disputes and lack of appropriate terms and conditions that could result in incomplete delivery, financial loss, and could expose IBM to legal and regulatory risk.

Approach:

Obtain a listing of all contracts (including contracts acquired from other organizations) that were in effect during the audit period and select a judgmental sample based on high risk factors (core, regional/niche, nonstrategic, Procurement Integrity Focus suppliers, high-dollar, diversity suppliers). Review the contracts selected against the control questions (refer to section of the Blue Book).

Assessment Questions

1. Did all contracts for the organization (base contracts, statements of work (SOW), confidentiality agreements, equipment loan agreements) have appropriate approvals from line management, finance, legal, tax, and procurement before the effective date? If not, was there any delivery of goods or services provided by the supplier prior to obtaining the last signature? Were approvals within delegated commitment authority? If a model procurement agreement (MPA) was not used, were legal approvals obtained for any variance to non-commercial (Legal) terms before submitting a contract to the supplier?
2. Was there a process in place to ensure contract files received from other organizations were in compliance with procurement policy? Did contract files acquired from other organizations contain proper documentation and adhere to procurement policy? If the contract file was determined to be unsatisfactory, what did the procurement organization do to develop an action plan to update these contracts?
3. Did the contract have all required terms and conditions? Did it include the requirement to not sub-tier without documented permission of the IBM buyer? Were flow-down terms (required IBM terms and conditions) appropriately included? For sub-tiering of PIF suppliers, refer to section SA002.P.
4. Was the scope of work clearly defined and were rates clearly identified? Specifically, did the scope of work include:
 - Defined job classifications for time and materials contracts
 - Defined job responsibilities for contractors
 - Reporting requirements to provide data for confirmation of services performed
 - Clauses regarding the use of subcontractors
 - Invoicing requirements
 - For Intermediaries or distributors, was a defined maximum fee defined for providing integrator/distributor services?
5. Did the contract comply with corporate requirements for doing business with former IBMers, close personal friends, or relatives? If any IBM employees were permanently located at the supplier, or vice versa, did the contract protect IBM from joint-employer relationship exposures?
6. Were deliverables specified in the contract?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Primary Test: Contract Administration (CM0001.P)

(Continued)

7. Was a change control process in place to identify who was authorized to update the contract and the scope of work?
8. Was a firm, fixed, not-to-exceed price stipulated in the contract? If so, was the scope of work clearly defined and the effort independently validated? If not fixed price, was there clear documentation as to how price would be determined? NOTE: This should include supplier mark-ups, where applicable. For Cost Plus agreements, was a provision allowing IBM the right to audit appropriate records to support invoiced charges included in the contract?
9. Were all actual costs incurred, including overtime, extra charges, etc. being measured against the costs specified in the contract or purchase order?
10. Were cancellation terms and costs and the methodology for determining settlement, clearly defined in the contract?
11. Were contract terms in accordance with quoted terms for price, delivery, quality, and discount?
12. If the audit clause had been exercised, were the results reviewed and actions taken where necessary?
13. Were contracts processed and loaded into Buy@IBM in a timely manner?
14. Contracts containing rebates: Was there a documented list of rebates in place, and were those rebates collected from the suppliers in line with the contract terms?
15. Were appropriate approvals obtained for contract change and cancellation costs?
16. Were the rates contained in the invoices consistent with the rates identified in the contracts and POs?
17. Were delivery and payment terms consistent with those in the contracts?
18. Were contracted rates similar for contracts with similar deliverables?
19. Were agreements to protect the privacy of IBM and supplier data in place for all e-procurement relationships?
20. Were all active procurement agreements, including customer supplier agreements in an outsourced arrangement, loaded into Buy@IBM? If the contract was not scanned into Buy@IBM, was there sufficient information provided to locate the contract in a timely manner? Were the appropriate Terms and Conditions from the procurement approved template used for all documents?
21. Verify that all terms and conditions of the contract were being monitored and executed properly. If a contract clause required activity by IBM or the supplier, was that activity being performed (ex. insurance certificates, measurements, deliverables).

Note: Procurement does not monitor contract deliverables that are in the responsibility of the requester/client.

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Primary Test: Contract Administration (CM0001.P)

(Continued)

22. If a purchasing organization that work with contractors reaches out to Procurement, verify if contract management education on IBM's contractor guidelines was provided. Select a sample of active agreements involving contractors and verify that this education took place whenever it was required by the purchasing organization. This education should take place before contractors come to an IBM facility and again as necessary to maintain proper awareness of the IBM contractor guidelines.
23. Interview the country tax manager to identify any concerns from a tax perspective including tax ramifications of executed contracts.
24. Are there any Power of Attorney documents in place? If yes, verify the following:
 - What is the Procurement policy for establishing a Power of Attorney document?
 - Were all Power of Attorney documents drafted or reviewed by a Legal representative - prior to implementation - to ensure the Power of Attorney is compliant with local laws and regulations that are applicable to the IBM legal entity / entities referenced in the document?
 - Are there regular reviews (e.g., annual) of active Power of Attorney documents to ensure they are compliant with local laws and regulations? Does a Legal representative participate in these reviews?
 - Are all of the active Power of Attorney documents utilized by Procurement stored in a central location (on country level)?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Secondary Test: Time and Material (CM002.S)

Objective:

To validate if controls over agreements were adequate to ensure proper administration of the purchase activity and a well-defined business relationship between IBM and its suppliers. Specifically, to verify if the process for time and material (T&M) contracts was effective in keeping costs to a minimum.

Approach:

1. Could the work have been adequately specified to allow for a firm, fixed price contract? Was time and material the best type of agreement to meet IBM and customer requirements?
2. Were all required approvals obtained?
3. Was a provision allowing IBM the right to audit appropriate records to support invoiced charges included in the contract? Were these rights exercised periodically?
4. Was there proper separation of duties between requester of services, procurement issuance of purchase, and receipt of services?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Primary Test: Assets and Suppliers (CM003.P)

Objective:

To validate if controls over agreements were adequate to ensure proper administration of the purchase activity and a well-defined business relationship between IBM and its suppliers. Specifically, to verify if assets loaned were adequately controlled to prevent supplier relations problems and the loss of IBM assets.

Approach:

1. From the location's property control system and from the location's loan agreement tracking system, obtain a listing of all capital assets identified as being located at a supplier where the agreements were executed by Procurement. Select a sample for review. In addition, review the consigned parts process and select a sample for review.
2. For the sample selected, test against the following criteria:
 - Was an Equipment and Program Loan Agreement (EPLA) in place, if required?
 - If parts were consigned, was there an approved consignment agreement?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Secondary Test: Confidential Information (CM004.S)

Objective:

To validate if controls over agreements were adequate to ensure proper administration of the purchase activity and a well-defined business relationship between IBM and its suppliers. Specifically, to verify if IBM and supplier confidential information was adequately protected.

Approach:

Obtain a listing of the organization's Procurement Agreement for Exchange of Confidential Information (PAECI), Non-Procurement Agreement for the Exchange of Confidential Information (NP-AECI), Confidential Disclosure Agreement (CDA) or any other document outlining the sharing and exchange of confidential information that were in effect during the audit period. Select a sample and test against the following criteria:

NOTE: During the audit (review), determine if proprietary/confidential supplier information is labelled as confidential. This would include, but is not limited to price analysis, supplier evaluations, and performance report summaries reflecting all core and strategic suppliers and rankings.

1. Were the sensitive accounts and denied parties lists checked prior to approval of the agreement?
If required, was the appropriate IBM counsel contacted?
2. Was the release of confidential information properly approved?
3. Did Legal approve confidential agreements where there was a need to impose or accept restrictions on the use of the confidential information?
4. If the discloser was concerned that the supplier's facilities or procedures might not have been sufficient to protect the information was a security review performed prior to release of confidential information?
5. If a security review was conducted was a notice sent to the Procurement Policy Executive?
6. If the security review noted exposures, were they corrected?
7. Was the receipt or disclosure of technical confidential information approved by the appropriate individuals?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Primary Test: Business Continuity (CM005.P)

Objective:

To validate if controls over agreements were adequate to ensure proper administration of the purchase activity and a well-defined business relationship between IBM and its suppliers. Specifically, to verify if suppliers had an adequate business continuity plan in place.

Approach:

Suppliers need to agree to have and maintain a business continuity plan and business continuity testing procedures, which include but are not limited to the areas of disaster recovery planning and pandemic planning. Suppliers need to agree to review, update, and test the business continuity plan annually and, upon buyer's request, suppliers need to provide a summary of the business continuity plan and test results. The supplier remains solely responsible for the performance of its responsibilities under the agreement and the adequacy of the business continuity plan regardless of whether the buyer has reviewed or commented on the plan.

1. Check if the contract with the supplier includes the business continuity clause.
2. Check if the supplier has provided the business continuity plan and test results.

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 3. Contract Management and Supplier Deliverables

Primary Test: Agreement Currency (CM006.P)

Objective:

To validate if controls over agreements were adequate to ensure proper administration of the purchase activity and a well-defined business relationship between IBM and its suppliers. Specifically, to verify if controls existed to minimize the impact to costs from currency fluctuations for purchase orders (POs) and contracts with foreign suppliers.

Approach:

Obtain a listing of POs and contracts with multiple or large dollar buys from foreign suppliers where the commitment was made in a currency that is different from the IBM entity's functional currency for the audit period. Also, request payment records for each agreement. Select a sample and test against the following criteria:

1. If the pricing in the PO or contract was defined in a currency other than the IBM entity's functional currency, did the value exceed the threshold defined in Treasury's Foreign Exchange Guidelines for Procurement? If so, was approval obtained from Regional or CHQ Treasury?
2. Verify that none of the following situations (as defined in Treasury's Foreign Exchange Guidelines for Procurement) applied for the PO or contract:
 - The use of a restricted currency
 - The use of fixed exchange rates for future payments
 - The use of currency indexing or currency masking
3. Where reference to a currency exchange rate was included for a PO or contract, was a publicly available source that publishes or releases an official rate (opening, closing, etc.) agreed with the supplier?

Data Universe:

The universe of contracts can be pulled here: [Contract Audit Report](#)

Filtering is available for Geography, Region, Country. Contract types can be Master Agreement, Stand Alone Agreement and Sub Agreement. Contract amendment types are Administrative, Amendment, Renewal, and Termination. Contract status can be draft, draft amendment, expired, closed and published.

Available reports from Technology Team:

None

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Purchase Order Process

Procurement Task:

Committing IBM funds to external suppliers requires at least two independent approvals:

- From the Requester, who secures approvals and funding, governed by Corporate Instruction FIN 101.
- From Procurement, who authorizes the commitment, supplier selection, price, terms, and conditions, governed by Corporate Organization Letter 131.

A Work Authorization (WA) is defined as the buyer's authorization for a supplier to conduct transactions, which can be in the form of a Purchase Order (PO). The PO serves as both a Work Authorization and a standalone agreement for processing IBM purchases.

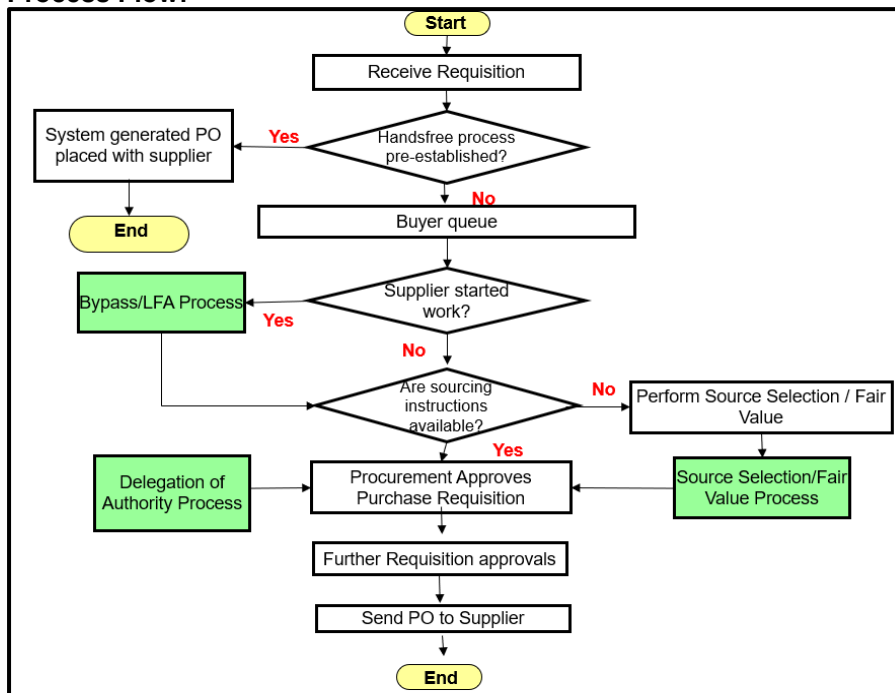
Types of POs:

- Hands-on Requisitions is created when there is no identified and implemented Hands-free solutions, and sourcing information control is performed by the Buyer. After Procurement revision, and subsequent approvals, the Purchase Order is released.
- Hands-free PO is an automated Purchase Order generated when a Requester raises a requisition through identified and implemented Hands-free solutions as pre-approved by Buyers and enabled by HF COE team. Example of Hands-free solutions is a catalog order.

Reference:

Blue book Section Purchase Orders / Work Authorization and related link to Publisher [PO Issuance Guidelines](#)

Process Flow:



PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Purchase Order Process
(Continued)

Objective:

To validate if adequate controls over the purchase order (PO) / work authorization (WA) processes are in place to protect IBM's interests and verify that IBM received the best value. Specifically, to verify if the processes were effective to ensure commitments were made to a supplier that has successfully completed the supplier on-boarding process, or for a supplier whose revalidation process is current, purchases were valid and approved, and IBM's interests were protected.

Risk/Exposure:

Failure to adequately control the PO process could lead to unauthorized expenditures, increased costs, and supplier relationship issues. Bypassing the procurement process may result in excessive costs and could lead to unauthorized commitments and expenditures.

Failure to adequately control the non-PO process could lead to unauthorized expenditures, increased costs, and supplier relationship issues. Bypassing the procurement process may result in excessive costs and could lead to unauthorized commitments and expenditures.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Purchase Order Process

Primary Test: Purchase Orders and Work Authorizations (PO001.P)

Objective:

To validate if adequate controls over the purchase order (PO) / work authorization (WA) processes are in place to protect IBM's interests and verify that IBM received the best value. Specifically, to verify if the processes were effective to ensure commitments were made to a supplier that has successfully completed the supplier on-boarding process, or for a supplier whose revalidation process is current, purchases were valid and approved, and IBM's interests were protected.

Approach:

Select samples of POs/WAs using data analysis and risk-based auditing techniques. Test for the following attributes:

1. Was there a valid business purpose? Was an appropriate business justification submitted with the purchase requisition? Was the appropriate Commodity/UNSPSC Code used?
2. Was the PO sent to a supplier that has successfully completed the supplier on-boarding process, or to a supplier whose revalidation process is current? NOTE: Suppliers 'inactive' for more than five years must go through onboarding requirements before re-activation (as per section 2.9.1).
3. Were all requester and procurement (or delegated) approvals obtained prior to commitment to a supplier?
4. Was the price on the PO provided to the supplier, equal to the price contained in the accepted arrangement (contract, price list, quote, or cost estimate)?
5. Did the PO specify terms for invoicing, including applicable tax treatment, payment terms, and the delivery of goods or services?
6. Did the PO commitment amount equal the actual payment(s) amount?
7. Was the PO issue date prior to the accounts payable invoice date? If not, was this investigated to determine if the PO should be coded as a bypass or exception, was this determination properly documented, and appropriate action taken?
8. Did the purchase order contain the correct source selection code? Was there a process to validate the accuracy of source codes entered into the PO system? If inaccurate sources codes were identified, were they corrected in a timely manner, and were actions taken as appropriate?
9. Was fair value determination performed for those purchase orders identified as bypasses, which were over the organization's clip level?
10. Were all PO alterations within the permitted variances defined in the Policy Guide located <https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/alteration-approval-guidelines>, or was there documented approval from the requester?
11. Were cancellation charges properly approved?
12. Were any premium charges such as premium freight and overtime approved by the requester and procurement as per the organization's approval process?
13. Were delegations and/or clip levels circumvented by placing multiple purchase orders to the same suppliers?
14. Obtain the Requisition Cycle Time Report to determine POs with large cycle time between requisition and PO placement (requisition processing more than 20 days). Determine if the requisition cycle time was greater than a specified local target (i.e., ten days). Determine the causes for the delays.

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Purchase Order Process

Primary Test: Purchase Orders and Work Authorizations (PO001.P)

(Continued)

15. If unit-less POs were used (the unit designation in SAP/CAAPS is 'UL' or 'VAL' in Buy@IBM), request a list and select a sample for testing. Samples should focus on high-dollar value, purchases that were paid with multiple invoices, and purchases with descriptions that could be itemized into individual units. For each PO determine if:
 - The use of the UL designation was appropriate. Could the purchase have been defined in units?
 - Procurement was able to determine exactly what was purchased and performed any required fair value analysis.
 - Management implemented regular UL PO reviews. Review the methodology for selecting UL POs for this testing to ensure complete coverage of UL activity.
 - Controls were in place to verify that IBM received and was billed for only what was ordered through proper procurement channels. (The negative confirmation process with accounts payable is not sufficient since this will go to the requester.)
 - The measurements and use of UL designations complied with procurement requirements.
16. If payment terms are based on any other date than the one outlined in the Blue Book, verify if approval was obtained.
17. For any POs where early payments to the supplier are requested, verify that the Expedite and Immediate Payment process was followed, and the appropriate level of approval was obtained. (See Procurement Policy at [Expedite and Immediate Payment Process](#))
18. Were all requirements as defined in the Blue Book completed prior to the issuance of the WA/PO?
19. If a Scope Of Work (SOW) serves as the WA, was it designated as such within the SOW?
20. If POs are issued for an in-process agreement (e.g., base agreement, SOW) verify if the requirements as set-forth in the Blue Book were followed.
21. If POs were executed with the appropriate IBM affiliate and in cases involving multiple IBM affiliates, verify that corresponding participation or base agreements are in place.
22. If the transaction requires the supplier to be involved with any handling (for example, hosting, encrypting, modifying or deleting) of IBM Personal Information/Sensitive Personal Information (PI/SPI) or IBM client PI/SPI, was a Data Processing Agreement (DPA) in place?

Control questions for Data Privacy (one of both)

- **IBM as Controller:** Request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link:
<https://ibm.ent.box.com/file/1198251968388>
- **IBM as Processor:** Select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link:
<https://ibm.ent.box.com/file/1198263127550>

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Purchase Order Process

Primary Test: Letter of Authorizations (PO002.P)

Objective:

To validate if adequate controls over the purchase order (PO) / work authorization (WA) processes are in place to protect IBM's interests and verify that IBM received the best value. Specifically, to verify if controls over the letter of authorization (LOA) process were effectively designed and executed to ensure commitments were made to on-boarded suppliers, purchases were valid and approved, and IBM's interests were protected.

Approach:

Review the local LOA process and obtain a list of all LOAs issued to suppliers during the audit period.

1. Was the LOA approved by Procurement and Finance to cover the committed value?
2. Were all required checks, if applicable (for example, criminal background check, rehire eligibility check, import/export approval) performed prior to starting or continuing work?
3. Were all requirements contained in the Blue Book (<https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/letter-of-authorization>) completed for new suppliers?
4. Were all PIF supplier requirements (if applicable) fulfilled?
5. Was there an end date or a "not-to-exceed" value included in the LOA?
6. Was there a process to track the aging of LOAs, and documented approvals for LOAs aged greater than 30 days?
7. If the transaction requires the supplier to be involved with any handling (for example, hosting, encrypting, modifying, or deleting) of IBM Personal Information/Sensitive Personal Information (PI/SPI) or IBM client PI/SPI, was a Data Processing Agreement (DPA) in place?

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 4. Purchase Order Process

Primary Test: Approval of Commitments (PO003.P)

Objective:

To validate if adequate controls over the purchase order (PO) process are in place to protect IBM's interests and verify that IBM received the best value. Specifically, to verify that there were adequate controls over the process for committing funds for IBM.

Approach:

1. Obtain copies of local procedures for committing funds. Validate that the procedures comply with Corporate Instruction FIN 101 by requiring a minimum of two independent approvals: (1) requester approval authorizing the release of IBM funds, and (2) procurement approval authorizing the supplier selection, price, and terms and conditions. In addition, did procedures specify that approvals for alterations are based on the difference in the committed amount? Test for proper approvals in "Purchase Order Process (PO001.P)."
2. Obtain copies of Delegation of Procurement Authority from the IBM Chief Procurement Officer. Adherence to these delegations will be tested in "Purchase Order Process (PO001.P)."
3. Obtain listings of all organizations to whom the procurement manager had delegated procurement authority. Obtain and review the document (DOU) between the two organizations. Determine if the procurement manager had established a review process which assures compliance to the DOU.
4. Determine that processes have been established to confirm that levels of approval have not been exceeded as contracts are updated, renewed, or scope of work is changed.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Procurement Bypass

Objective:

To validate if bypass controls outside of purchase order processing were adequate to prevent circumvention of the established IBM Global Procurement process. This includes validation if non-PO invoices were accurate and in line with the procurement guidelines and process requirements.

Risk/Exposure:

Failure to adequately control the non-PO process could lead to unauthorized expenditures, increased costs, and supplier relationship issues. Bypassing the procurement process may result in excessive costs and could lead to unauthorized commitments and expenditures.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Procurement Bypass

Primary Test: Procurement Bypass Identification (PB001.P)

Objective:

To validate if bypass controls outside of purchase order processing were adequate to prevent circumvention of the established IBM Global Procurement process. Specifically, verify if Procurement had an effectively designed, executed, and controlled process for monitoring bypasses and circumvention of the documented procurement process. Also, validate if non-PO invoices were accurate and in line with the procurement guidelines and process requirements.

Approach:

Purchases without a PO

1. Obtain a list of all non-PO invoices (IOI = for CAAPS countries, low-value and PO-exempt = for SAP countries) paid by IBM during the audit period and utilize data analytics reports to select samples.
2. Obtain a list of the authorized PO-exempt Commodity Codes applicable for the audited country.
3. Obtain the country low value clip-level, and a list of the low value categories for the country.
4. Select a sample based on the following:
 - PO-exempt: categories which might allow for the circumvention of the procurement process
 - Low value: Commodity/ Codes which might allow for the circumvention of the procurement process
5. Test for the following:
 - Is there an effectively designed process to notify the line organization of any improper purchases made without purchase orders?
6. PO-exempt: Compare the invoice description with the selected PO-exempt code and verify whether it matched. If the description did not match with the selected code, verify whether another authorized PO-exempt code existed, and if not, determine whether it was a bypass.
7. Low Value: Compare the invoice description with the selected Commodity/ Code, verify whether it matched and whether it was below the low-value country clip level. If the invoice amount was above the low-value country clip-level, verify whether instead a PO-exempt purchase applied. If not, determine if it was a bypass.

If the invoice amount was below the low-value country clip-level verify if the invoice description aligned with the selected Commodity/ Code description, or if not, whether a more appropriate low value Commodity/ Code existed. If not, determine if the transaction represents a Procurement bypass.

Purchases with a PO

- For invoices issued by a supplier to IBM before IBM released the PO to the supplier, was a valid reason provided to explain this occurrence? Was this a bypass?
- For POs where the supplier invoiced IBM within a few days of receiving the PO, was there a valid reason for this occurrence? If not, was this a bypass?

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Procurement Bypass

Primary Test: Procurement Bypass Management and Reporting (PB002.P)

Objective:

To validate if bypass controls outside of purchase order processing were adequate to prevent circumvention of the established IBM Global Procurement process. This includes validation if non-PO invoices were accurate and in line with the procurement guidelines and process requirements. Specifically, to verify if circumventions of the procurement process were identified, properly reviewed and reported, and appropriate actions were taken to address these occurrences.

Approach:

1. For each PO selected for the Procurement Bypass sample, were all POs that were coded as a bypass listed in the bypass report?
2. Were notifications sent to employees with identified bypasses and their management, as per Procurement policy?
3. Did bypasses above the delegated clip levels have documentation to support fair value analysis and management approvals?
4. If a decision was taken by the buyer to not report a commitment of funds without following the procurement process, was buyer's decision documented and justified?
5. If bypasses are detected during the audit through 'Procurement Bypass Identification' testing, verify against the Control Risk Analysis measurement report and determine if adding these as bypasses for the reporting month will result in a missed target.
6. Was quarterly testing of non-purchase order categories performed, as required per the Blue Book?
7. If the bypass was for a supplier classified as a PIF supplier, was the bypass reviewed by the Ombudsman and Compliance & Investigations (C&I) Officer?

Data Universe:

1. [EPM Reports for Procurement Audit](#) In the section Procurement Audit look for PO reports report. Click on Folder symbol in the lower right corner to view more, if available New Vendor report. Filters to apply: Geo/Market/Country, Audit time frame, PO Codes
2. [S2P Data & Dashboards](#) In the section Procurement audit look for Active Vendor report. Filters to apply: Geo/Market/Country, Audit time frame, PO Codes

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 5. Procurement Bypass

Primary Test: Procurement Bypass Management and Reporting (PB002.P)

(Continued)

Available reports from Analysis Team:

1. GOE Transactions - POs created and invoices paid during the audit period that have been identified as GOE.
2. POTENTIAL PIF SUPPLIERS - The Supplier is a GOE or the End Customer is a GOE.
3. PO Create Date - POs created 30 days or less after Vendor was created.
4. Service Start Date - Work was potentially performed prior to the PO being created.
5. PO Committed Amount Greater than PO Requisition (Note: This report is for CAAPS POs only / not applicable for Buy@IBM P2P countries).
6. PO Payment Exceeds PO Commit.
7. PO Issued After Contract Expiration - Work was potentially performed without an executed contract.
8. Invoiced Before PO - Work was potentially performed prior to the PO being created.
9. Non-Handsfree Transactions - Purchase orders that are not handsfree require additional steps within the procurement process to ensure that IBM receives fair value and proper selection.
10. Invoices with "Unassigned" or "Not In Use" Commodity Codes – potential incorrect commodity codes were used.
11. Sole Selection – is the supplier selected the only supplier that can fulfill the PO?
12. Customer Directed - An Externally Directed Customer Transaction indicates that IBM's customer has identified the vendors that will be used on the contract.
13. Intermediaries - Intermediary transactions (involve multiple suppliers, which may require additional vetting and financial oversight).
14. Late / Early / Timely Payments - While 'timely' payments are more of an Accounts Payable audit test, this report is good information to assist in selecting and validating samples.
15. Sub-Contractor work period greater than one year - Sub-Contractors purchase orders may have exceeded contract limits and/or potential country labor laws allowances, exposing IBM to additional financial costs. Additionally, a sub-contractor period greater than 1 year may limit the possibility of using IBM employees (resource management concern).
16. Vendor Address is a PO BOX - A vendor address having a PO BOX may indicate that the vendor is a 'dummy' company, which may lead to fraud.
17. PO / Non PO - Vendors that have both PO and Non POs may indicate a potential bypass of the Procurement process.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Measurements and Key Controls

Procurement Task:

Report internal performance on a quarterly basis.

Reference:

MSAC – see Instructions for FBC OpenPages

Process Flow:

N/A

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Measurements and Key Controls

Primary Test: Procurement Internal Measurement (MA001.P)

Objective:

To validate if procurement has an effective process for measuring its internal performance.

Risk/Exposure:

Ineffective key control compliance testing could result in incorrect transactions remaining undetected and could expose IBM to financial loss and misstatements.

Approach:

1. Was the appropriate level of management given visibility to procurement performance measurements?
2. Were corrective actions taken when targets were not met, or concerns were identified? Were action plans tracked to completion or until the issue was resolved? Were they appropriate?
3. Were internal measurements identified to manage risk for the commodity or organization being audited? The following are samples of potential measurements (as applicable within each country or geography):
 - a. Cost versus estimates (high dollar parts tracking)
 - b. Requisition cycle time, with aging
 - c. Blocked receipts
 - d. Aging of late deliveries
4. Were any system referrals to buyers and exceptions aged, tracked, and worked both at the buyer level and in total?
5. Were measurement methodologies reviewed and approved by management on a regular basis?
6. Annual Source Selection and Fair Value Coverage Requirements
 - a. Verify that the 2% sourcing exception target threshold was not exceeded.
 - b. Verify that the 1% bypass target threshold was not exceeded.

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Measurements and Key Controls

Primary Test: Diversity Certification and Spend Reporting (MA002.P)

Objective:

To validate if Procurement has an effective process for measuring its internal performance. Specifically, to verify if diverse supplier certificates were maintained by the Supplier Diversity Department to validate data reported to the U.S. Federal Government, commercial customers, and executive management was accurate and met IBM spend guidelines. Additionally, to verify that measurements provided to management were accurate and provided visibility to key aspects of the U.S. Supplier Diversity Program and determine if appropriate actions were taken to address identified concerns.

Approach:

<https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/inclusive-supplier-engagement>

Testing for Supplier Diversity Department (to be used as applicable in a procurement/outsourced manufacturing process audit - BUT - also to be used in a Supplier Diversity audit):

1. Certification
 - a. A copy of an actual certificate or other document with an expiration date from an appropriate non-government organization (NGO), state, local or federal government agency is accepted to support a supplier's diverse status. IBM accepts certifications from many agencies, including:
 - The National Minority Supplier Development Council (NMSDC) and its regional affiliate councils
 - Central Contractor Registration (CCR) - 8a, SDB, woman-owned SDB, Hubzone programs
 - A State, Local, or Federal Government Agency
 - Women's Business Enterprise National Council (WBENC)
 - National Gay and Lesbian Chamber of Commerce (NGLCC)
 - b. Review the diverse supplier measurements reported to management and validate that appropriate diverse certificates were on file for all reported expenditures.
 - c. Review the measurements reported to IBM management and verify that they have appropriate visibility to the diverse supplier certification process. Do the measurements include certification compliance information?
2. Internal and External Reporting
 1. Verify the diverse status claimed by the supplier to validate the integrity of reported diverse expenditures.
 - Spend that occurs via a partnership created between a diverse supplier and a majority supplier and the diverse supplier provides no value add (performs no services or minimal amount) to the process. This situation is also referred to as a "Pass through" and is strictly prohibited by IBM.
 - Spend that is reported as 1st tier diverse spend that is actually 2nd tier diverse spend (internal only)
 - Select a sample of the latest Forms 294 and 295 (reported to the Federal Government) with complete detail by supplier and verify that all reported expenditures were able to be validated by proof of diverse (minority, women, etc.) certification.
 - Obtain the standard data presented to commercial customers upon their request and validate that there is diverse certification on file.

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Measurements and Key Controls

Primary Test: Diversity Certification and Spend Reporting (MA002.P)

(Continued)

3. Testing for Procurement Organizations

Obtain a listing of diversity suppliers. This would include female, minority, disabled, veteran, and other. Analysis of the supplier type reports will provide an evaluation of the location's effort to place workload with these types of suppliers. Select a sample of suppliers from the listing to determine if:

- Diversity suppliers were correctly recorded in the procurement systems and if the classification into tier 1 (direct spend) and tier 2 (indirect spend) was accurately recorded.
- Measurements reported to the Supplier Diversity Department were accurate and could be supported by systems data.

Data Universe:

The following hyperlink points to the EPM Diversity Dashboard

[EPM - Diversity Dashboard](#)

Available reports from Technology Team:

None

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 6. Measurements and Key Controls

Primary Test: Separation of Duties and System Access (MA003.P)

Objective:

Determine if the SOD assessment process was effective to identify conflicting roles and responsibilities. This includes all current employees and contractors.

Approach:

Verify that:

1. The end-to-end process was reviewed at least annually and at the appropriate level, and the results were documented and approved by the process owner or delegate.
2. Identified conflicts were assessed for a determination and there was supporting documentation to validate the assessment. Focus on individuals who had responsibilities for performing more than one of the following procurement-related activities:
 - Defining product or service requirements for the purchase. (For example, quantity and date required or scope of work.)
 - Selecting the supplier and also determining price, terms, and conditions.
 - Attesting that the goods and services were received.
 - Processing documents for payment.
 - Secondary controls were identified, where needed, and that they mitigate the conflict effectively.

Obtain system access records for procurement personnel and verify that they do not have access to accounts payable, ordering, and/or receiving systems. Also, verify that there exist no conflicting system access duties within each system and between systems for each individual. Verify that non-procurement personnel have no access to Procurement systems.

Verify that system access has been removed for any employee and contractor who is no longer in the department and/or has no further continued business need.

Data Universe:

N/A

Available reports from Technology Team:

None

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Environmental Programs

Procurement Task:

IBM Supply Chain's Social and Environmental Management System (S&EMS) is an integral part of IBM's corporate responsibility and supports its commitment to environmental leadership in all its business activities. The S&EMS integrates our existing supply chain social responsibility, environmental programs and requirements into a single management system that aligns with IBM's Global Environmental Management System (EMS).

Reference:

<https://w3.ibm.com/w3publisher/procurement/sourcing/policies-practices/sems>

Process Flow:

The supplier onboarding process in EcoVadis IQ involves adding the supplier to IBM's network, determining if a sustainability assessment is required based on risk level and supplier type, and following specific setup steps. If an assessment is required, the buyer/sourcing owner ensures the supplier participates and completes it, and the Sustainable Procurement team addresses any corrective actions needed within 12 months.

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Environmental Programs

Primary Test: Import of Third-Party Products (EP001.P)

Objective:

Do procedures and controls over environmental requirements for third party products ensure that these requirements are fulfilled?

Risk/Exposure:

Failure to properly fulfill the environmental requirements can lead to financial loss and damage to the IBM brand.

Approach:

Test import of third-party products and environmental requirements for supplier Deliverables to IBM. Is the IBM organization responsible for the procurement of third-party products for direct resale to IBM customers/clients where IBM acts as the importer of record (IoR) and may the products be subject to environmental laws, regulations, or requirements (e.g., for IT hardware or chemicals)? If yes, verify that:

1. The Procurement organization considered sourcing options available for third party products such as buying in the country of the customer delivery or using local, regional, or international distributor models which would prevent IBM being identified as the importer of record.
2. The third-party product suppliers have been approved per the direct ship process (<https://w3.ibm.com/w3publisher/direct-ship-process>) for the countries where the products will be imported by IBM.
3. The supplier's roles and responsibilities to support compliance activities for sale, shipment, and importation of their products by IBM have been defined and formalized (e.g., per contract provisions or other enforceable processes).

PROCUREMENT AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Environmental Programs

Primary Test: Procurement of Waste Disposal and Product Recycling Services (EP002.P)

Objective:

To determine if all suppliers providing hazardous waste, special waste, and end-of-life product management (treatment, recycling, and/or disposal) services are evaluated and approved by Corporate Environmental Affairs prior to their use by IBM.

Approach:

Is the organization responsible for the procurement of the following services: Recycling and/or disposal of hazardous waste, recycling, and/or disposal of end-of-life information technology (hardware) products?

If yes, verify that all such suppliers have been evaluated and approved by Corporate Environmental Affairs per the requirements of Corporate Instruction ENV205.

Data Universe:

The universe of new/active suppliers can be pulled out of EPM:

1. PO Reports pre-built directly in EPM:
[EPM Reports for Procurement Audit](#) In the section Procurement Audit look for Purchase order report – Filter on relevant codes
Filters to apply: Geo/Market/Country, Audit time frame, SS, FV codes
2. PO Reports available in publisher page:
[S2P Data & Dashboards](#) In the section Procurement audit look for PO reports
Filters to apply: Geo/Market/Country, Audit time frame, PO, SS, FV codes
Customer Directed Negotiation Codes are BH and PH

Available reports from Analysis Team:

1. Sole selection report
2. Customer directed report

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 7. Environmental Programs

Primary Test: Environmental Requirements for Supplier Deliverables to IBM (EP003.P)

Objective:

To verify that an effective process exists to communicate IBM's environmental requirements to suppliers and to collect required environmental declarations from suppliers.

Approach:

Is the organization responsible for the procurement of materials, parts, and or other deliverables for incorporation into IBM products? If yes, verify that:

1. The Procurement organization has a process implemented to communicate IBM's environmental requirements (including IBM's Engineering Specification - ES 46G3772) to all suppliers providing parts or deliverables for use in IBM products.
2. The Procurement Organization has implemented a process to collect and manage product content declarations from suppliers for all materials, parts, and deliverables used in IBM products. Test a representative sample of recently purchased parts and verify that product content declarations are available.

Data Universe:

N/A

Available reports from Technology Team:

None

PROCUREMENT

AUDIT PROGRAM #44-00-00

CONTROL ASSESSMENT QUESTIONS

Key Control Question: 8. Measurements and Key Controls

Primary Test: Separation of Duties and System Access (MA003.P)

Procurement Task:

Separation of duties is the act of keeping activities separated that could result in the misuse or loss of assets.

No individual (person or virtual) should be able to control multiple stages of a process or sub-process in which fraud, material errors, or waste could occur without deterrence or timely detection.

Separation of duties is the recognition that the combination of business tasks or system/application accesses with other tasks and accesses could result in the loss or misuse of assets.

Reference:

[FIN 182 - Appendix C](#)

Process Flow:

Review of Procurement SOD Assessment is required at least annually by SOD Assessment owner.

- Procurement Policies and Practices Procurement First Line Leader to approve annual SOD Assessment.
- Global SOD Assessment to be included in universe for annual KCFR006 testing

Objective:

To validate if Procurement has an effective process for measuring its internal performance. Specifically, to validate if a separation of duties (SOD) assessment was performed and approved by the process owner or delegate annually, or more frequently as necessary. Validate that identified SOD conflicts are eliminated, mitigated, or accepted based on risk severity. Validate that conflicting tasks which should be separated, but are not, have effective secondary controls in place.

Risk/Exposure:

Separation of Duties (SOD) directs that no one individual has responsibilities and/or access that would allow the individual to misuse or divert company assets or perpetrate fraud without deterrence or timely detection.

Approach:

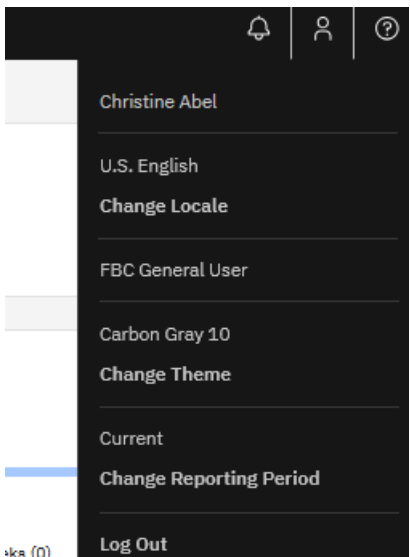
Review FIN182 - Management Self Assessment of Control, Appendix C - Separation of Duties.

PROCUREMENT AUDIT PROGRAM #44-00-00

Appendix A: Instructions for FBC OpenPages

For MSAC (2025 onwards), access OpenPages using the following link: <https://ibmgrc-prod01.op.ibmcloud.com/openpages>

Select the reporting period that you want to see information by selecting the person icon then selecting the Change Reporting Period



MSACs are stored by Business Unit, Global Process, Geo Process, and so on, which can be accessed through the dashboard or hamburger icon at the top left

